嵌入式安全已不再是可选功能

原创 Brian Williams 嵌入式系统专家之声 2026年8月26日 08:00 北京

点击上方"蓝字" 关注我们吧！

嵌入式系统专家之声
嵌入式系统专家之声依托嵌入式系统联谊会专家团队，汇集嵌入式系统产、学、研和媒体...
310篇原创内容

公众号

本文字数：4547
预计阅读时长：12分钟

作者：Brian Tristam Williams（Elektor）
翻译：何灵渊

编者的话

可以访问一个设备就意味着可以攻击这一设备。嵌入式安全决定开放的访问是否会变成弱点。本期我们继续刊登介绍嵌入式系统安全设计的文章，这里讨论的安全即包括信息安全，也包括功能安全，既有安全设计也有安全规范。本篇的观点："将嵌入式安全看作是"锦上添花"的时代已经过去了，每一个联网设备都是安全相关的。"



今天，嵌入式系统安全是任务关键的，事后才考虑它的工程师最终会需要重新设计系统，修补可以避免的错误，或是看着自己的产品登上漏洞列表[1]。

嵌入式世界展览会[2]连续几届都在反复传达这一信息，现状也变得愈发显而易见。当绝大多数微控制器、传感器节点、家用电器、工业控制器、可穿戴设备和汽车子系统都联网时——直接或是间接，全互联网都是攻击表面。在2026年部署没有安全措施的MCU无异于在1999年发售向全球启用文件分享、没有防火墙的PC。

这是针对当前行业现状采取的务实的措施。现如今，软件供应链攻击[3]、固件篡改[4]以及物联网设备群被入侵都已成为常态。人们期待嵌入式系统领域能够具备传统的“大型”IT系统的特性：私密性、完整性、真实性和健壮性。不同的是，嵌入式系统必须在低功耗、小尺寸和数十年的生命周期的条件下提供这些保证。

如果工程师不在早期就重视这些需求，就必须在之后花费大量精力进行修复。

不断扩展的威胁模型：所有物都在互相通信

十年前，一个运行控制循环的8位微控制器[5]不会引发网络安全的担忧，它一般会通过一个简单的串行总线进行通信，并且位于网关的背后。今天，同一级别的设备可能会与下面的组件进行通信：

- IP网络无线模块
- 云服务
- 多种供应商SDK和第三方库
- 移动应用（通过蓝牙低功耗）
- 部署后可以接受更新的设备上引导程序

换言之，这样的设备已经不是隔绝的了。即使低成本、最小化的设计也和外界连通（有时是通过其他子系统间接连接的）。

一旦有了连通性，典型的IT攻击就会出现：

- 伪造的固件升级
- 窃取凭证
- 侧信道泄露
- 通过恶意包裹进行远程代码执行
- 供应链攻击（恶意的开发工具、有注入的库、被篡改的二进制文件）

这些并不仅是理论上的可能，工业IoT应用、消费电子，甚至汽车的电子控制单元（ECU）都曾因为固件更新、调试接口和不安全的配套应用而被入侵过。

最大的转变是攻击者不再关心设备自身的价值，没有人会担心洗碗机被远程启动，但是僵尸网络、拒绝服务式攻击（DDoS）基础设施和横向移动攻击意味着即使一个智能灯泡也值得进行入侵[6]。

当每一个节点都可能成为防御的滩头阵地时，工程团队不能假设设备太小或是隐藏得好就不会被攻击。

硬件正在缩小差距

好消息是，芯片厂商已经意识到了问题所在，多数新的微控制器和SoC上搭载了过去只配套高端应用处理器的功能：

- 安全引导
- 硬件信任根
- 片上存储（PUF[7]、HSM模块、单次可编程区域）
- 隔离执行区（Arm TrustZone-M[8]、RISC-V PMP）
- 密码学加速器
- 篡改监测和主动保护（某些安全MCU）

缺乏安全能力不是最大的挑战，而是许多团队依然没有开启或者使用这些功能。4个最主要的原因为：

> 安全功能会让开发变得复杂，需要小心的配置，以及在默认的电路板引导流程中不存在的数字签署过程。

> 安全功能的文档往往是针对供应商的，并且十分碎片化。一种Cortex-M33芯片的安全引导过程会与另一种有所不同。

> 截止日期临近时，安全看上去会是“额外的工作”。安全功能会被推迟到“第二阶段”（往往根本不存在）。

> 团队缺乏统一的安全意识。固件工程师、硬件设计师、开发运维和云开发者通常将安全视为“其他人的问题”。

硬件已经做好了准备，开发过程经常尚未看齐。

当下的安全需求

健壮的嵌入式安全不仅关乎单独的功能，而是端到端的信任：

可信任的硬件基础

- 只读的ROM引导程序

- 数字签署的固件
- 可验证的更新路径

设备的安全身份

- 唯一的密码学密钥
- 基于证书的授权
- 密钥不会离开MCU

抵御漏洞的利用

- 内存保护单元
- 编译器安全强化
- 降低固件的攻击表面

数据存储和传输的保护

- 片上加密存储
- TLS[9]或者其他安全信道

安全的开发过程

- 可复现的构建[10]
- 严格控制的数字签署基础设施
- 依赖项的漏洞扫描

生命周期管理

- 可修补性和OTA更新
- 监控和集群分析[11]
- 生命周期结束时的安全退役

关键点是：安全不再是附加的功能，而是贯穿设计、制造、部署及维护全过程的持续性工作。

工程师面临的挑战

从爱好者的项目到工业部署，不同行业的技术人员都会遇到类似的问题：

部分实现的安全引导信任链

开发者数字签署了第一步的引导程序，但并没有签署应用镜像，或者依赖于开发时使用的开放调试密钥。

弱密钥和密钥重用

非常多的设备在发布时依然存在下面的问题：

私有密钥是整个生产线共用的

硬编码的凭据

固件中嵌入了对称密钥

一旦密钥泄露，整个集群都会变得不安全。

OTA升级跳过完整性检查

即使在2026年，一些设备依然通过http下载更新，不进行签名验证！这依然是最简单的IoT设备攻击路径。

过分相信“隐蔽既安全”

封闭的固件、不常见的MCU、私有协议和其他用于迷惑的方法不能保护任何人，特别是当下。攻击者时常会对少见的架构进行逆向分析。

没有长期维护计划

产品通常能够活跃10到20年，供应商能够坚持3到5个产品周期，云后台不断更替。安全计划很少做出充分的准备。

工程师可以采取的切实行动

如果想要一蹴而就，实现安全看上去非常困难。最好的方法是将安全嵌入到设计中，而不是之后再附加上来。

从硬件信任根开始

如果MCU或者SoC支持安全引导，一开始就开启它。在编写应用代码之前，提前搭建你的固件签署和部署过程。这样就能避免“我们之后再谈安全”的问题。

为每一部设备准备密钥

现代MCU自带硬件密钥存储，应该在生产或者首次引导时生成独特的凭据，最好是在设备上生成。

降低固件攻击表面

禁用不需要的外设、通信栈和调试接口，最小化第三方代码。每一个用不到的驱动都是一个可能的攻击路径。

强制执行有验证的更新

更新必须通过配备传输层安全（TLS，DTLS等）的方式进行，必须验证镜像的密码学数字签名。

尽早进行威胁建模

我们只需要30分钟的有建设性的讨论，而不是50页来自咨询公司的报告：

> 攻击者会看到什么？
>
> 攻击者如何取得控制？
>
> 攻击者如何进行物理访问？
>
> 取得物理访问后会发生什么？

这样，我们就能阻止设计缺陷成为架构问题。

将安全计划记录为文档

如果你的团队不能确切描述密钥的存储方法、固件更新的验证机制，或者设备的引导链，你的设备不能算是安全的，只能算是幸运的（到目前为止）。

提前考虑安全能够节约时间和金钱

安全通常被视为是昂贵的延期。现实中，实施过程往往是“省小钱亏大钱”，这是因为不安全的系统要昂贵得多：

- 固件有漏洞导致召回
- 在时间压力下进行紧急更新
- 数据泄露后的客户流失
- 监管问题，特别是医疗、工业和消费者IoT市场
- 无法修复的重大问题导致产品生命周期的缩短

在设计周期早期就投入力量和资本进行安全架构设计和部署，能够避免许多年的更新和补救。

另一个好处是：安全的设备能在更长的时间内保持可用。如果硬件的固件和升级过程是可信的，你可以在发布的若干年后继续部署功能、补丁，甚至是全新的工作流程。

嵌入式工程师的新责任

正在发生的转变很简单：任何有固件的设备都是安全相关的。工程师不只是在搭建功能，更是在建立信任。无论你是在编程微小的Cortex-M0+，强力的Linux级SoC，还是新近兴起的RISC-V平台，期望都是一样的。

社区、市场，甚至是法律[12]都期望设备的默认行为是安全的。

2026年的纽伦堡嵌入式世界展览会反映了业界广泛的转型：从“安全是附加的”到“安全是基础架构”。将MCU视为独立的控制块的时代已经过去，它们都是全球化系统的节点，安全影响远比自身的功能要大。

让你的未来变得安全

嵌入式安全不像AI加速器或是超低功耗无线电那样令人振奋，但是它能决定你的设备在实际场景中能否存活，被信任，并且不要成为下一个典型的IoT攻击案例。

如果你在构建嵌入式系统，安全现在就是你的职责了，而不是事后附加的配件。

参考链接

[1]美国国家安全漏洞数据库：https://nvd.nist.gov/

[2]嵌入式世界展览会：https://www.embedded-world.de/en

[3]“针对政府机关、关键基础设施及私立组织的高级持续性威胁（APT）入侵”，CISA.gov，2021年：https://www.cisa.gov/newsevents/cybersecurity-advisories/aa20-352a

[4]“固件完整性验证、监控与报告工具（映射到NIST指南）”，网络安全创新论坛，NIST.gov，2015：https://csrc.nist.gov/presentations/2015/firmware-integrity-verification,-monitoring-and-re

[5]“从8位微控制器开始：Tam Hanna专访”，elektormagazine.com，2020：

本文授权来自合作伙伴Elektor媒体集团，如果希望免费订阅Elektor的英文在线内容，请访问https://www.elektormagazine.com/

相/关/推/荐

设计保障安全-通过基础工程手段限制失效

基于安全模组的嵌入式系统安全启动设计

嵌入式系统安全与可信技术发展趋势

嵌入式系统专家之声推荐搜索

嵌入式系统 | SafeRTOS | AI

【点击上方👆搜索词条可查看号内更多其他内容】



关注我们，了解更多精彩内容

转发，点赞，在看，安排一下?

专家观点 · 目录

上一篇 · 包云岗：RISC-V赛道，呼唤嘉立创模式